# 信息安全测评与风险评估

5.2 模拟人员访谈

授课教师：张玉



# 目录

CONTENTS


01 案例导入——“一个访谈引发的真相”

02 学习目标

03 安全管理测评中的访谈——为什么必不可少？

04 访谈的定义与在等保测评中的定位

# 案例导入——“一个访谈引发的真相”

## 案例素材

某测评机构进行等保测评。文档核查阶段制度齐全、记录完整。

测评师：“贵单位是否定期更换密码？”

管理员：“制度规定90天更换一次。”

测评师：“最近一次更换是什么时候？”

管理员：“一年前？平时太忙没人检查。”

- **引入问题**

  安全管理测评中，什么是“通过交谈获取证据”的关键环节？

- **问题讨论**
  - 该单位的安全制度真的“执行到位”了吗？

核心结论

访谈是安全管理测评中“验证真实性”的关键手段。

# 学习目标

## 通过本课学习，你将能够：

- 理解人员访谈在安全管理测评中的核心作用
- 掌握访谈的目的、类型与基本流程
- 能够设计针对不同岗位的访谈提纲
- 能够运用访谈技巧获取关键信息并准确记录
- 具备沟通协作能力、法治意识与职业判断力

# 安全管理测评中的访谈——为什么必不可少？

**安全管理测评与技术测评最大的区别是：技术测的是“设备”，管理测的是“人”。**

## 01 验证真实性

**制度“写没写”≠“做没做”**

例如：制度规定90天改密码，实际一年没改

## 02 了解执行细节

**流程“有没有”≠“执行到位”**

例如：有应急预案，但员工从未演练过

## 03 发现隐性风险

**文档不会写“我们省事”**

例如：安全管理中的“省事”操作，只有通过访谈才能发现

## 04 交叉验证

**同一问题问不同人，判断一致性**

例如：安全主管说“定期培训”，员工说“没参加过”

# 访谈的定义与在等保测评中的定位

**GB/T 22239-2019 安全管理测评——证据采集方法：安全管理测评可通过文档查阅、人员访谈、记录审查等方式采集证据。**

**访谈在等保测评标准中的依据**

| 标准条款 | 访谈目的 |
| --- | --- |
| 8.1.7.4 沟通和合作 | 了解组织机构间的协作机制 |

## 安全管理测评“三大取证手段”的关系

**01 文档查阅**

证据是**“静态”**的

（制度文本、审批记录）

**02 记录审查**

证据是**“痕迹”**的

（日志、表单、台账）

**03 人员访谈**

证据是**“动态”**的

（口头陈述、行为描述）

# 访谈的目的

安全管理测评中访谈的四个核心目的：

## 核实制度执行

制度规定的措施是否真的落实了？

## 评估人员意识

相关人员是否了解安全要求？是否具备安全操作能力？

## 了解实际操作

实际工作流程与制度规定是否一致？有没有“省事”的变通做法？

## 交叉验证信息

文档记录、操作日志与口头描述是否一致？

# 访谈的类型

## 结构化访谈

**适用：**标准化的测评项目、大规模测评。

**特点：**问题固定、格式统一、结果可比。

## 半结构化访谈

**适用：**针对特定岗位或发现异常时。

**特点：**核心问题固定，可追问细节。

## 非结构化访谈

**适用：**探索性调查、发现新问题。

**特点：**开放式对话、灵活调整。

## 在安全管理测评中的应用建议

- 通常采用**半结构化访谈**。
- 提前准备核心问题，过程中根据回答灵活追问。

# 访谈的基本流程

## 访谈五步法

### 1 准备

确定访谈对象、设计访谈提纲

**关键要点**

了解岗位职责、准备核心问题

### 2 预约

提前通知被访谈人

**关键要点**

说明访谈目的和大致时长

### 3 执行

正式开展访谈

**关键要点**

注意提问技巧、做好记录

### 4 核实

对关键信息进行确认

**关键要点**

对存疑点进行追问或交叉验证

### 5 记录

整理访谈记录

**关键要点**

及时整理、签字确认

# 访谈对象——该访谈谁？

**安全管理测评中常见访谈对象及关注点：**

- **安全主管/负责人** 制度建设、策略制定、事件管理、安全投入
- **系统管理员** 账户权限、日常运维、补丁管理、备份执行
- **安全管理员** 策略执行、安全配置、安全审计、安全巡检
- **普通员工** 安全意识、安全培训接受情况、制度了解
- **第三方/外包人员** 访问权限管控、保密协议签订、服务管理

# 访谈提纲——针对系统管理员的访谈示例

| 访谈问题 | 追问方向 |
| --- | --- |
| 1. 请简要介绍一下您的岗位职责。 | 确认岗位职责范围，判断是否存在“身兼多岗” |
| 2. 系统目前有哪些用户？账户是如何管理的？ | 账号创建、权限分配、离职账号清理 |
| 3. 密码策略是如何设置的？是否定期更换？ | 密码复杂度、更换周期、是否强制？ |
| 4. 系统补丁是如何管理的？ | 补丁更新流程、测试评估、紧急补丁处理 |
| 5. 系统日志是否开启？日志如何保存和审查？ | 日志保留期限、是否定期审查 |
| 6. 如果系统出现安全事件，您会怎么做？ | 应急处理流程、上报机制 |

# 访谈提纲——针对安全管理人员的访谈示例

| 访谈问题 | 追问方向 |
| --- | --- |
| 1.贵单位的安全管理组织架构是怎样的？ | 是否有专职安全岗位？职责是否明确？ |
| 2.是否制定了安全管理制度？制度多久评审一次？ | 制度是否覆盖各维度？是否经过审批？ |
| 3.安全培训是如何开展的？多久一次？ | 培训内容、覆盖范围、是否有考核 |
| 4.是否有安全事件应急预案？是否进行过演练？ | 预案内容、演练频率、演练效果 |
| 5.第三方人员访问系统需要什么流程？ | 审批流程、权限控制、离场清理 |

# 访谈技巧——如何有效提问

## 开放式提问

**获取完整信息**

“请介绍一下您的岗位职责。”

## 封闭式提问

**确认具体事实**

“您是否参加过安全培训？”

## 追问

**深挖细节**

“您能具体说说上次培训是什么时候吗？”

## 澄清

**确保理解正确**

“您刚才说的是不是这个意思……”

## 对比

**发现不一致**

“制度规定是90天，实际执行的情况是？”

**关键原则：多问“如何”（How），少问“是否”（Yes/No）。**

# 访谈技巧——如何识别“说一套做一套”

## 常见信号及应对策略：

01 **回答模糊：“大概、可能、基本上……”**

应对策略 追问具体细节：“您能具体描述一下吗？”

02 **回避直接问题：“这个我不太清楚，应该是……”**

应对策略 追问执行主体：“这件事是谁负责的？”

03 **前后矛盾：前面说“定期培训”，后面说“没有参加过”**

应对策略 记录下来，后续交叉验证

04 **过度承诺：“我们100%按照制度执行”**

应对策略 追问例外情况：“有没有出现过例外？”

05 **转移话题：“这个要问我们领导”**

应对策略 坚持：“您作为执行者，具体情况是怎样的？”

# 教师示范访谈（10分钟）

素材1：访谈场景卡（完整版）.docx

## 角色

- 测评师：教师扮演
- 被访谈人：学生扮演（提前指定）

## 场景

教师模拟对某单位“系统管理员”进行访谈

## 示范重点

1. **如何开场**
   自我介绍、说明目的、承诺保密
2. **如何按照提纲提问**
3. **如何追问**
4. **如何记录关键信息**
5. **如何收尾**

# 实践任务——模拟人员访谈（35分钟）

## 任务名称

模拟人员访谈

## 任务场景

模拟某单位等保测评项目，测评师需对被测方人员进行访谈

## 访谈场景

① 系统管理员访谈

② 安全主管访谈

③ 普通员工访谈

## 任务内容

1 确定访谈角色 → 2 设计访谈提纲 → 3 模拟访谈 → 4 记录访谈要点 → 5 填写《人员访谈记录表》

## 分组安排

**3-4人/组：**

分别扮演：测评师、被访谈人、记录员

# 访谈角色卡——系统管理员

## 角色卡1：系统管理员（张三）

岗位：系统管理员，负责3台服务器、2个数据库的日常运维

## 实际执行情况（供角色扮演者参考）：

**01 密码策略**

制度规定90天更换，实际“没时间换”，使用默认密码或简单密码

**02 账户管理**

离职员工账号未及时清理，有3个离职员工账号仍存在

**03 日志审计**

审计日志虽开启，但“没人看”

**04 补丁管理**

补丁更新不及时，“怕出问题，能不更新就不更新”

# 访谈角色卡——安全主管



## 角色卡2：安全主管（李四）

**岗位职责：**负责制定安全管理制度、组织安全培训

## 实际执行情况（供角色扮演者参考）

### 01 安全制度

制度已制定，但**“审批流程还没走完”**，制度未正式发布。

### 02 安全培训

今年只进行了一次全员培训，且**“走过场”**，未考核。

### 03 应急预案

预案已制定，但**“从未演练过”**。

### 04 风险评估

未定期开展，**“没人懂”**如何做。

# 访谈角色卡——普通员工



## 角色卡3：普通员工（王五）

岗位：业务部门普通员工，使用OA系统办公

**实际执行情况（供角色扮演者参考）：**

**01 安全意识**

不太清楚安全制度的具体内容

**02 安全培训**

参加过1次培训，“没太听懂”

**03 密码管理**

使用“生日+姓名首字母”作为密码，“好记”

**04 安全事件**

曾经收到过可疑邮件，“没多想就点了”附件

# 实践任务——填写《人员访谈记录表》（10分钟）

## 任务内容

1. 整理访谈记录
2. 填写《人员访谈记录表》
3. 初步判断安全问题

| 《人员访谈记录表》模板 | | | |
|---|---|---|---|
| 受访人姓名 | | 受访人岗位 | |
| 访谈时间 | | 访谈地点 | |
| 访谈要点记录 | 1.<br>2.<br>3. | | |
| 初步判断与发现的问题 | 1.<br>2. | | |
| 下一步核查建议 | | | |
| 测评师签名 | | 日期 | |

# 知识点回顾（5分钟）

素材3：课后作业
——模拟访谈练习.

**思维导图**
**核心内容**

## 一、定位：验证执行（技术测设备，管理测人）

取证手段：文档查阅 + 记录审查 + 人员访谈

## 二、访谈五步法

准备 → 预约 → 执行 → 核实 → 记录

## 三、访谈对象与提纲

对象：安全主管、管理员、普通员工（针对岗位设计问题）

## 四、访谈技巧

多问“如何”少问“是否”，追问具体并交叉验证，识别真实情况

## 五、访谈记录

及时整理，关键信息需签字确认

# 感谢观看

